

CATEGORY 4 – SAP GRC ACCESS CONTROL

Chapter 2 – Access Risk Analysis (ARA)

Q11. What is Access Risk Analysis (ARA)?

Interviewer's Objective

The interviewer wants to determine whether you understand ARA as a **risk governance solution**, not merely a report.

Executive Answer

Access Risk Analysis (ARA) is the SAP GRC module responsible for identifying, analyzing, and managing authorization risks across SAP landscapes.

It evaluates users, roles, profiles, and HR objects against predefined business risk rules to detect:

- Segregation of Duties (SoD) conflicts
- Critical Access
- Critical Permissions
- Sensitive Transactions
- Custom Risk Rules

ARA enables organizations to proactively identify security risks before access is provisioned and continuously monitor existing access throughout the user lifecycle.

Business Objective

ARA helps answer one simple question:

"Does this access introduce unacceptable business risk?"

Q12. What types of Risk Analysis can be performed in ARA?

Executive Answer

SAP GRC supports multiple types of analysis.

1. User Level Risk Analysis

Checks risks assigned to a specific user.

Example

User

↓

BALAJI

↓

Roles

↓

Risk Analysis

↓

High Risk Found

2. Role Risk Analysis

Checks whether a role itself contains SoD conflicts.

Useful during:

- Role Design
 - Role Modification
 - S/4HANA Migration
-

3. Profile Analysis

Checks authorization profiles instead of roles.

Less commonly used.

4. HR Object Analysis

Analyzes risks assigned through HR organizational structures.

5. Organizational Rule Analysis

Evaluates SoD considering:

- Company Code
- Plant
- Purchasing Organization
- Sales Organization

This significantly reduces false positives.

Q13. What is the difference between User Risk Analysis and Role Risk Analysis?

User Risk Analysis

Evaluates assigned roles

Used before access review

User-specific

Daily operations

Role Risk Analysis

Evaluates the role itself

Used during role design

Role-specific

Project implementation

Interview Tip

During an S/4HANA implementation, perform **Role Risk Analysis before assigning roles to users**. This prevents SoD issues from being introduced into production.

Q14. Explain the ARA Architecture.

Executive Answer

The architecture consists of several logical components.

Business Rule Set

↓

Business Functions

↓

Actions

↓

Permissions

↓

Authorization Objects

↓

Users / Roles

↓

Risk Report

Explanation

Business Rule Set

Contains all SoD definitions.

↓

Business Functions

Business activities such as:

- Vendor Maintenance
- Invoice Posting
- Payment Processing

↓

Actions

Transactions

Fiori Apps

Web Services

↓

Permissions

Authorization Objects

↓

Risk Engine

Performs analysis.

↓

Report

Displays:

- High
- Medium
- Low

Risk findings.

Q15. Explain the Rule Set.

One of the most frequently asked Architect questions.

Executive Answer

A Rule Set is the foundation of ARA.

It defines:

- Risks
- Functions
- Actions
- Permissions
- Mitigation
- Risk Severity

Without a Rule Set,

ARA cannot perform meaningful analysis.

Rule Set Hierarchy

Risk

↓

Function

↓

Action

↓

Permission

Example

Risk

Vendor Creation vs Vendor Payment

↓

Function 1

Maintain Vendor

↓

Actions

BP

XK01

XK02

↓

Function 2

Vendor Payment

↓

Actions

F110

FBZP

↓

Permission

Authorization Objects

If both functions are assigned,

↓

SoD Violation.

Q16. What are Functions in SAP GRC?

Executive Answer

Functions represent logical business activities.

Examples

- Create Vendor
- Maintain Customer
- Release Purchase Order
- Execute Payment
- Maintain User

A function groups related transactions that perform the same business task.

Example

Function

Vendor Maintenance

Actions

BP

XK01

XK02

XK03

Instead of creating risks using individual transactions,
SAP GRC evaluates business functions.

Q17. What are Actions?

Executive Answer

Actions are executable business operations.

An Action can include:

- Transaction Codes
- Fiori Applications
- Web Services
- Programs

Example

Function

Purchase Order Creation

Actions

ME21N

Create Purchase Order App

Q18. What are Permissions?

Permissions are the actual authorization checks.

Examples

Authorization Objects

M_BEST_BSA

M_BEST_WRK

S_TCODE

Permissions provide the technical validation behind business actions.

Q19. Explain Risk Severity.

Organizations classify risks based on business impact.

Example

Severity Example

High Vendor Creation + Payment

High User Administration + Role Assignment

Medium Customer Master + Sales Order

Low Report Execution

Risk severity should be defined jointly by:

- Internal Audit
 - Business Owners
 - Security Team
 - Compliance
-

Q20. How do you customize an ARA Rule Set?

This is an Architect-level question.

Executive Answer

I follow a structured governance approach.

Step 1

Review SAP Standard Rule Set.



Step 2

Meet Business Process Owners.



Step 3

Identify custom business processes.



Step 4

Map custom transactions.



Step 5

Create Business Functions.



Step 6

Create Risks.



Step 7

Assign Severity.



Step 8

Test in QA.



Step 9

Business Validation.



Step 10

Production Deployment.

Interview Tip

Never modify the SAP-delivered rule set directly.

Maintain a customer-specific version so that SAP support packs and upgrades do not overwrite your organization's customizations.

Q21. What is Organizational-Level Risk Analysis?

Executive Answer

Organizational-Level Risk Analysis evaluates SoD conflicts while considering organizational values.

Example

User has

Vendor Creation

Company Code 1000

AND

Vendor Payment

Company Code 2000

Without organizational analysis,

↓

High Risk.

With organizational analysis,

↓

No practical SoD conflict because the activities apply to different company codes.

Benefits

- Fewer false positives
- Better business alignment

- More accurate reporting
 - Higher confidence in risk assessments
-

Q22. How do you reduce false positives in ARA?

One of the most practical interview questions.

Executive Answer

False positives occur when GRC reports a theoretical conflict that is not possible in practice.

I reduce them by:

- Maintaining organizational rules (Company Code, Plant, Purchasing Organization, etc.)
- Removing obsolete transactions from the rule set.
- Validating custom transactions and Fiori apps.
- Eliminating duplicate actions.
- Reviewing role design to ensure least privilege.
- Periodically cleansing unused roles and authorizations.
- Updating the rule set after business process changes.

The goal is to ensure that ARA highlights genuine business risks rather than overwhelming reviewers with unnecessary findings.

Q23. ARA Performance Tuning

Interviewer

"Risk Analysis is taking several hours. How would you troubleshoot it?"

Executive Answer

I would investigate the issue systematically:

1. Verify the scope of the analysis (users, roles, systems).
2. Check the health and consistency of the rule set.
3. Review connector performance and RFC connectivity.

4. Analyze background job execution and scheduling.
5. Ensure indexes and database statistics are current.
6. Remove duplicate or obsolete actions from the rule set.
7. Validate that unnecessary organizational levels are not increasing processing complexity.
8. Coordinate with Basis to review system resources if required.

Performance tuning should preserve accuracy while improving execution time.

Real Interview Scenario

Interviewer

"A business user's access request fails because ARA identifies a High SoD risk. The business insists the access is essential. What would you do?"

Executive Answer

I would not bypass the risk simply because the business requests it.

My approach would be:

1. Review the ARA findings to confirm the conflict.
2. Validate whether the requested access is genuinely required for the user's responsibilities.
3. Check if the conflict can be resolved through role redesign or by removing unnecessary access.
4. If separation is not operationally feasible, discuss compensating controls with the business and Internal Audit.
5. If the organization accepts the residual risk, document it through an approved mitigation control in SAP GRC and obtain the necessary approvals.
6. Schedule periodic reviews to ensure the mitigation remains appropriate.

This approach balances operational requirements with governance and ensures the decision is transparent, documented, and auditable.

Senior Consultant Interview Tips

- Explain **business impact**, not just configuration.

- Emphasize that ARA should be used **during role design**, not only after users are provisioned.
 - Highlight collaboration with business owners, auditors, and compliance teams when defining rule sets and risk acceptance.
 - Distinguish between **theoretical** SoD conflicts and **actual** business risk by discussing organizational-level analysis and compensating controls.
-

End of Chapter 2

The next chapter will cover **Access Request Management (ARM)** in depth, including:

- ARM architecture
- End-to-end request lifecycle
- MSMP workflow
- BRF+ routing
- Provisioning methods
- Integration with ARA
- Common approval workflows
- Troubleshooting stuck requests
- Manufacturing-specific approval scenarios
- Real-world interview case studies

This is another core topic for senior SAP GRC interviews and directly aligns with the responsibilities in your target job description.